Garder un secret sans le connaître

Le hachage des mots de passe

Séquence
SQ04

Partie
P04

Niveau
BTS SIO 1re année

Objectifs

- **Expliquer** comment un site vérifie un mot de passe sans l'enregistrer.
- **Décrire** les propriétés d'une fonction de hachage.
- **Justifier** l'usage du sel et d'une fonction lente.

Prérequis : la page de connexion (le mot de passe arrive en clair au serveur), la réutilisation des mots de passe et les dictionnaires.

Le serveur reçoit `velo`. Il en fait quoi ?

La semaine dernière : le mot de passe quitte le navigateur et arrive **en clair** au serveur. Il faudra le vérifier à chaque connexion.

Si le site enregistre…	Qui peut le lire ?	Si la base est volée
Le mot de passe en clair	Tout administrateur, tout voleur	Tous les comptes, et les autres sites où il est réutilisé
Le mot de passe chiffré	Celui qui a la clé	Tout, si la clé est volée avec la base
Une **empreinte** du mot de passe	Personne	Pas de retour possible au mot de passe

Une fonction de hachage

Elle transforme n'importe quel texte en une **empreinte** de taille fixe. SHA-256 : 64 caractères.

Propriété	Ce que ça veut dire
Déterministe	Même texte, même empreinte, sur n'importe quel ordinateur
À sens unique	Impossible de retrouver le texte à partir de l'empreinte
Effet avalanche	Un caractère change : l'empreinte change entièrement
Taille fixe	`velo` ou un roman : toujours 64 caractères

Un caractère, tout change

Texte	Début de l'empreinte SHA-256
`velo`	`cd1e45e8b94d27b2…`
`Velo`	`5d1e437e74a365f9…`
`velo␣` (avec une espace)	`dcb58e1533c6df96…`

Aucune ressemblance entre les empreintes, alors que les textes sont presque identiques : l'empreinte ne laisse rien deviner du texte.

Vérifier sans enregistrer

1 · À L'INSCRIPTION

Mot de passe choisi
velo

→ **Fonction de hachage**
SHA-256, bcrypt, Argon2…

↓

Enregistré dans la base : l'empreinte seulement
cd1e45e8b94d27b2562ab5ae45b4bff6
1e2bc89d9ca4ffe117e70aa5ac8ef1eb

lue →

2 · À CHAQUE CONNEXION

Mot de passe saisi
velo

→ **Même fonction**
même empreinte si même texte

↓

Comparaison des deux empreintes
celle qui vient d'être calculée
et celle enregistrée à l'inscription

Identiques → connexion acceptée

Différentes → connexion refusée

Le site n'a jamais eu besoin de garder le mot de passe.

3 · SI LA BASE EST VOLÉE

Le voleur obtient des empreintes, pas des mots de passe :
la fonction est à sens unique, on ne remonte pas au texte.

Limite : il peut hacher des mots courants et chercher les empreintes identiques.
D'où le sel et les fonctions lentes.

À retenir · un site sérieux ne connaît pas votre mot de passe : il garde son empreinte et compare.

ATTENTION

La limite : les mots de passe courants

Même texte, même empreinte : c'est utile pour vérifier, mais aussi pour l'attaquant.

Ce que voit le voleur dans la base	Ce qu'il en déduit
Deux comptes ont la même empreinte	Ils ont le même mot de passe
Une empreinte égale à celle de `azerty`	Le mot de passe est `azerty`

Il lui suffit de hacher les mots de passe courants et de **comparer**. Un mot de passe aléatoire et long, lui, n'est dans aucune liste.

Le sel : une valeur différente pour chaque compte

À l'inscription, le site tire au hasard un **sel**, l'enregistre, et hache **sel + mot de passe**.

Compte	Sel (enregistré)	Mot de passe	Empreinte enregistrée
Léa	`x7Qk`	`azerty`	`0b7ef626e317…`
Hugo	`p2Lm`	`azerty`	`4ebe301aecee…`

Même mot de passe, empreintes différentes : on ne repère plus les doublons, et une liste d'empreintes préparée à l'avance ne sert plus à rien. Le sel n'est pas un secret : il protège par sa **diversité**.

Rapide ou lente ?

	SHA-256	bcrypt, Argon2
Conçue pour	Vérifier vite des fichiers, des téléchargements	Stocker des mots de passe
Vitesse	Des milliards d'empreintes par seconde	Volontairement lente, réglable
Pour l'utilisateur	—	Une connexion : quelques centièmes de seconde, invisible
Pour l'attaquant	Essayer une liste entière : rapide	Chaque essai coûte : des années au lieu de minutes

Pour les mots de passe : une fonction lente, avec un sel, comme le recommandent l'ANSSI et la CNIL.

Hacher n’est pas chiffrer

	Chiffrer	Hacher
Retour au texte	Oui, avec la clé	**Jamais**
Clé	Indispensable	Aucune
Usage	Protéger un message à relire : HTTPS, disque	Vérifier sans connaître : mots de passe, intégrité d’un fichier

Le même principe sert aussi à vérifier qu’un fichier téléchargé n’a pas été modifié : on compare son empreinte à celle publiée par l’éditeur.

ACTIVITÉ

Vérification individuelle

Sur papier · seul · 5 minutes

À produire : quatre réponses courtes, corrigées ensemble.

1. Pourquoi le site n'a-t-il pas besoin de garder le mot de passe ?
2. Deux comptes ont la même empreinte SHA-256 sans sel : qu'en conclure ?
3. À quoi sert le sel, puisqu'il n'est pas secret ?
4. Un site vous renvoie votre mot de passe par courriel quand vous l'oubliez : que révèle-t-il ?

À RETENIR

À retenir

Notion	En une phrase
Empreinte	Résultat d'une fonction à sens unique, de taille fixe
Vérifier	Hacher le mot de passe saisi et comparer à l'empreinte enregistrée
Sel	Une valeur aléatoire par compte : même mot de passe, empreintes différentes
Fonction lente	bcrypt ou Argon2 : chaque essai coûte cher à l'attaquant

En demi-groupe : calculer des empreintes, vérifier une connexion, constater l'effet du sel.